

Chapitre 4 : Les méthodes de tests d'applications

1. Les différents types de tests :

Type de test	Description
Tests unitaires	Tests de chaque fonction ou méthode individuellement
Tests d'intégration	Tests de l'assemblage de plusieurs fonctions ou méthodes
Tests de performance	Tests pour mesurer la performance de l'application
Tests d'acceptation	Tests effectués par le client ou l'utilisateur final pour valider l'application

Outils de test courants :

- **Selenium** : Un outil de test d'interface utilisateur pour les applications web ;
- **Pytest** : Un framework de test pour Python ;
- **Postman** : Un outil de test d'API pour les applications web.

E6 : Cybersécurité des services informatiques

Présentation de l'épreuve :

L'épreuve E6 « Cybersécurité des services informatiques » est coefficientée à hauteur de 4, ce qui représente 18 % de la note finale.

Il s'agit de la troisième et dernière épreuve professionnelle après l'épreuve E4 et E5.

Cette épreuve se déroule sous forme ponctuelle écrite (contrôle sur table) durant un examen d'une durée de 4 heures.

Conseil :

Cette épreuve E6 « Cybersécurité des services informatiques » est relativement nouvelle, elle a été créée pour répondre aux nouvelles exigences du secteur.

J'ai personnellement obtenu la note de 16/20 grâce à l'ensemble des informations ci-dessous. Il s'agira essentiellement d'apprentissage par cœur, il n'y aura que peu d'exercices au cours de cette épreuve. L'obtention d'une excellente note est donc plutôt « facile ».

Table des matières

Chapitre 1 :	Introduction à la cybersécurité.....	108
1.	Introduction à la cybersécurité : définition et enjeux	108
2.	Principes de base de la cybersécurité.....	108
Chapitre 2 :	Menaces et risques informatiques	110
1.	Introduction aux menaces informatiques	110
2.	Les virus informatiques	110
3.	Les logiciels malveillants	111
4.	Le phishing et le DDOS	111
5.	Les vulnérabilités des systèmes informatiques	112
Chapitre 3 :	Sécurité des réseaux	113
1.	Les menaces pour la sécurité des réseaux.....	113
2.	Les protocoles de sécurité	113
3.	Les pare-feux	114
4.	Les VPN.....	114
5.	Les bonnes pratiques	115
Chapitre 4 :	Sécurité des systèmes d'information	116
1.	La sécurité des systèmes d'exploitation	116

2.	La sécurité des applications.....	116
3.	La sécurité des bases de données	116
Chapitre 5 : Sécurité des données		118
1.	La classification et l'étiquetage des données	118
2.	Le chiffrement des données	118

Chapitre 1 : Introduction à la cybersécurité

1. Introduction à la cybersécurité : définition et enjeux :

Les enjeux de la cybersécurité :

- La protection des systèmes informatiques et des données contre les attaques malveillantes ;
- La garantie de la confidentialité et de l'intégrité des données ;
- La protection de la vie privée des utilisateurs.

Les acteurs de la cybersécurité :

- Les gouvernements ;
- Les entreprises ;
- Les organisations non gouvernementales (ONG) ;
- Les individus.

Les gouvernements jouent un rôle important dans la cybersécurité en développant des lois et des réglementations pour protéger les systèmes et les données sensibles.

Les tendances actuelles :

Les tendances actuelles en cybersécurité sont marquées par l'évolution rapide des menaces et des technologies. Les cyberattaques sont de plus en plus sophistiquées et visent des cibles de plus en plus diverses.

Les défis de la cybersécurité :

Parmi les défis les plus importants, on peut citer la complexité croissante des systèmes d'information et la sophistication des attaques.

Les acteurs malveillants, comme les hackers et les criminels, disposent de moyens de plus en plus avancés pour mener des attaques, ce qui rend la protection des systèmes informatiques de plus en plus difficile.

2. Principes de base de la cybersécurité :

Confidentialité :

La confidentialité est souvent atteinte à travers des méthodes de cryptage et de protection de l'accès aux informations.

Les techniques utilisées pour la confidentialité :

- Les mots de passe ;
- Les pare-feux ;
- Les réseaux privés virtuels (VPN) ;
- La gestion des identités.

L'intégrité :

Ce principe vise à assurer que les données ne sont ni altérées ni corrompues de manière non autorisée. En d'autres termes, il s'agit de s'assurer que les données sont fiables et que leur contenu n'a pas été altéré ou modifié par des personnes malveillantes.

La cryptographie :

La cryptographie désigne l'ensemble des techniques utilisées pour protéger les données en les rendant inintelligibles pour tout tiers qui tenterait de les intercepter. Elle repose sur l'utilisation de clés de chiffrement qui permettent de coder et de décoder les informations confidentielles.

La gestion des accès :

La gestion des accès peut être réalisée en utilisant des identifiants uniques, tels que des noms d'utilisateur et des mots de passe, ainsi que des systèmes d'authentification à deux facteurs qui requièrent une deuxième méthode d'authentification, telle qu'un code envoyé par SMS, pour confirmer l'identité de l'utilisateur.

Chapitre 2 : Menaces et risques informatiques

1. Introduction aux menaces informatiques :

Introduction aux menaces informatiques :

Les menaces informatiques sont des actes malveillants ou des événements qui visent à perturber, à endommager ou à accéder de manière non autorisée à des données, des appareils ou des réseaux informatiques.

Ces menaces peuvent causer des perturbations mineures, comme des virus ou des logiciels malveillants, ou des perturbations majeures, telles que des attaques DDoS ou des violations de données.

Les différents types de menaces informatiques :

Type de menace	Description
Virus	Programme malveillant qui se propage en infectant d'autres fichiers
Chevaux de Troie	Programme malveillant qui se cache dans un logiciel légitime pour accéder à des données ou prendre le contrôle d'un ordinateur
Ransomware	Programme malveillant qui bloque l'accès à un système ou à des fichiers jusqu'à ce qu'une rançon soit payée
Phishing	Technique d'ingénierie sociale qui vise à tromper les utilisateurs en leur faisant croire qu'ils communiquent avec une entité de confiance pour leur soutirer des informations confidentielles
Attaques par force brute	Attaque qui vise à trouver un mot de passe ou une clé en essayant toutes les combinaisons possibles
Attaques par déni de service (DDoS)	Attaque qui vise à rendre un service indisponible en surchargeant le système

2. Les virus informatiques :

Les différents types de virus informatiques :

- **Les virus de fichiers :** Infectent les fichiers exécutables et se propagent lorsque ces fichiers sont ouverts ou exécutés ;
- **Les virus de macro :** Infectent les documents contenant des macros, qui sont des scripts automatisés qui s'exécutent lors de l'ouverture du document ;

- **Les virus de boot :** Infectent les secteurs de démarrage des disques durs et se propagent lorsque l'ordinateur démarre à partir de ces disques ;
- **Les virus de script :** Infectent les fichiers de script, comme les fichiers JavaScript ou VBScript, et se propagent lorsque ces fichiers sont exécutés.

Les modes d'infection des virus :

Les virus informatiques peuvent être transmis par différents moyens, notamment les pièces jointes de courrier électronique, les fichiers téléchargés depuis Internet, les supports amovibles tels que les disques durs externes, les clés USB, les disques CD/DVD et les réseaux.

La prévention contre les virus :

Il est conseillé de ne pas ouvrir des pièces jointes provenant d'expéditeurs inconnus ou de sources non fiables.

Il est également important de ne pas télécharger des logiciels à partir de sites web suspects ou d'installer des programmes à partir de supports externes sans les avoir préalablement scannés avec un logiciel antivirus.

3. Les logiciels malveillants :

Les modes d'infection des logiciels malveillants :

Les "malwares" peuvent se propager par le biais de pièces jointes de courrier électronique, de logiciels piratés ou de liens malveillants.

Les conséquences des logiciels malveillants :

- La suppression ou la modification de données ;
- Le vol d'informations sensibles telles que les mots de passe et les informations de carte de crédit ;
- La prise de contrôle à distance du système infecté.

La détection et l'élimination des logiciels malveillants :

La détection des logiciels malveillants se fait à l'aide d'outils de sécurité tels que des antivirus, des pare-feux et des programmes de détection des malwares. Ces outils peuvent scanner le système et les fichiers à la recherche de toute trace d'un logiciel malveillant connu ou suspect.

4. Le phishing et le DDOS :

Le phishing :

Le phishing est une technique d'attaque informatique visant à obtenir des informations personnelles et confidentielles, telles que des identifiants de connexion, des numéros de carte bancaire ou des adresses e-mail. Les attaquants se font passer pour des organismes ou des entreprises connus.

L'attaque DDOS :

Une attaque par déni de service distribué (DDOS) est une technique malveillante utilisée pour rendre un serveur ou un réseau indisponible en inondant le service cible avec un trafic.

Les moyens de protection :

Pour se protéger contre le phishing, il est important de ne pas cliquer sur les liens ou les pièces jointes suspectes dans les e-mails et de vérifier l'authenticité des sites web avant de saisir des informations personnelles.

Pour se protéger contre les attaques DDOS, les entreprises peuvent mettre en place des mesures de sécurité telles que des pare-feux et des limites de bande passante pour filtrer le trafic malveillant.

5. Les vulnérabilités des systèmes informatiques :

Les différentes formes de vulnérabilités :

Les vulnérabilités peuvent être exploitées par des cybercriminels pour accéder à des informations sensibles, pour infecter des systèmes avec des logiciels malveillants, ou pour perturber le fonctionnement normal des systèmes.

Les modes d'exploitation des vulnérabilités :

- L'injection de code malveillant ;
- L'exploitation de failles de sécurité ;
- L'utilisation de programmes malveillants.

Les corrections des vulnérabilités :

Forme de vulnérabilité	Mode d'exploitation	Correction
Injection SQL	Injecter du code SQL malveillant via un champ de formulaire	Valider les entrées utilisateur et utiliser des requêtes préparées
Cross-Site Scripting (XSS)	Injecter du code JavaScript malveillant via un champ de formulaire ou un lien	Encoder les données utilisateur et filtrer les entrées
Accès non autorisé	Utiliser des identifiants volés ou des failles d'authentification	Renforcer l'authentification, limiter les accès et mettre à jour les identifiants
Faillles de sécurité des applications	Utiliser des failles de sécurité des composants matériels	Mettre à jour les pilotes, remplacer les composants vulnérables et utiliser des pare-feux

Chapitre 3 : Sécurité des réseaux

1. Les menaces pour la sécurité des réseaux :

Les différentes formes de menaces :

- Les attaques par déni de service distribué (DDoS) ;
- Les attaques de force brute ;
- Les attaques de phishing ;
- Les logiciels malveillants ;
- Les virus informatiques ;
- Les chevaux de Troie ;
- Les failles de sécurité des systèmes d'exploitation et des applications.

La détection et la correction :

Les menaces pour la sécurité des réseaux peuvent être détectées à l'aide de diverses techniques, telles que l'analyse des journaux, la surveillance du trafic réseau et les tests de pénétration.

Procédures mises en place pour les corriger :

- Mise à jour des logiciels et des systèmes ;
- Modification des politiques de sécurité ;
- Mise en place de contrôles supplémentaires.

2. Les protocoles de sécurité :

Les différents types de protocoles de sécurité :

Protocoles de sécurité	Description
SSL/TLS	Protocoles de cryptage pour la communication en ligne
PGP	Protocoles de cryptage pour la sécurisation des mails
SSH	Protocoles de sécurisation des connexions distantes
VPN	Protocoles pour la sécurisation des connexions à distance

Les protocoles de contrôle d'accès :

Les protocoles de contrôle d'accès sont utilisés pour assurer la sécurité des réseaux en contrôlant les accès des utilisateurs.

Exemples :

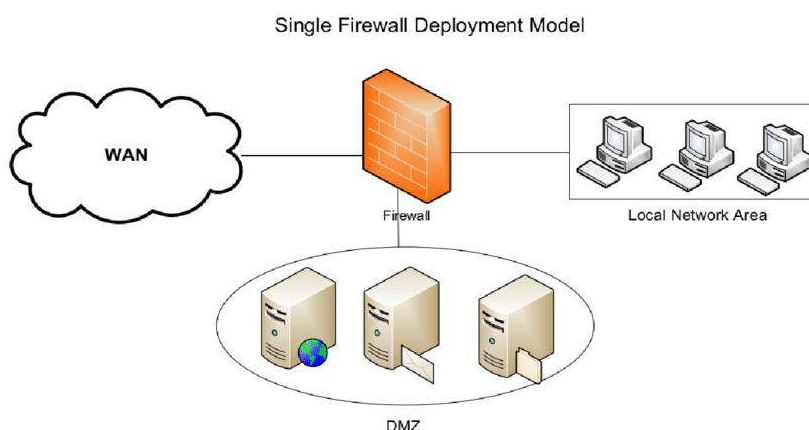
- Le protocole LDAP ;
- Le protocole SAML ;
- Le protocole OAuth.

3. Les pare-feux :

Les fonctions des pare-feux :

Les pare-feux permettent de protéger les réseaux en filtrant le trafic entrant et sortant. Les pare-feux peuvent être des dispositifs matériels ou logiciels et ils fonctionnent en bloquant le trafic qui ne répond pas à des règles spécifiques.

Les architectures des pare-feux :



Représentation schématique des pare-feux

4. Les VPN :

A quoi servent les VPN ?

Les VPN sont utilisés pour sécuriser les connexions à internet et protéger les données échangées entre les différents équipements d'un réseau, en les cryptant.

Exemple de protocoles de VPN :

Protocole de VPN	Description	Avantages	Inconvénients
PPTP	Point-to-Point Tunneling Protocol	Facile à configurer, rapide	Faible niveau de sécurité
IPsec	Internet Protocol Security	Sécurisé, cryptage de bout en bout	Configuration complexe
SSL	Secure Sockets Layer	Compatible avec différents systèmes, sécurisé	Peut être plus lent que d'autres protocoles
OpenVPN	Open-source VPN	Très sécurisé, personnalisable	Configuration complexe, requiert des compétences en informatique

5. Les bonnes pratiques :

Les bonnes pratiques pour les utilisateurs :

- Utiliser des mots de passe forts et uniques pour chaque compte ;
- Éviter de partager des informations personnelles ou confidentielles sur des réseaux publics ;
- Ne pas cliquer sur des liens suspects ;
- Garder à jour les logiciels et les systèmes d'exploitation ;
- Installer un antivirus et un pare-feu ;
- Sauvegarder régulièrement les données importantes.

Les bonnes pratiques pour les réseaux :

- Limiter l'accès aux informations sensible ;
- Installer et mettre à jour régulièrement des logiciels antivirus et antimalware ;
- Établir des politiques d'utilisation des réseaux pour les employés et les visiteurs ;
- Assurer la sécurité des connexions Wi-Fi en utilisant WPA2 ;
- Établir des sauvegardes régulières des données.

Comment bien gérer la sauvegarde et la récupération des données ?

- Établir une stratégie de sauvegarde et de récupération des données ;
- Réaliser des sauvegardes régulières des données ;
- Stocker les sauvegardes dans des endroits sûrs ;
- Tester régulièrement les sauvegardes ;
- Mettre en place des procédures d'urgence pour restaurer rapidement les données.

Chapitre 4 : Sécurité des systèmes d'information

1. La sécurité des systèmes d'exploitation :

Les vulnérabilités des systèmes d'exploitation :

Les vulnérabilités des systèmes d'exploitation peuvent inclure des erreurs de conception, des bogues de programmation et des configurations incorrectes.

Les outils permettant d'assurer une sécurité :

Modes d'exploitation des vulnérabilités	Outils pour assurer la sécurité
Attaque par déni de service (DDoS)	Pares-feux, Systèmes de détection d'intrusion
Ingénierie sociale	Formation des utilisateurs, Tests d'ingénierie sociale, Sensibilisation à la sécurité
Vulnérabilités logicielles	Mises à jour, Correctifs, Pares-feux, Antivirus, Antispyware
Vulnérabilités matérielles	Contrôles physiques, Sécurisation du matériel, Cryptographie
Vulnérabilités de configuration	Configuration appropriée, Contrôles de sécurité, Tests de pénétration

2. La sécurité des applications :

Les failles de sécurité des applications :

- Les injections SQL ;
- Les attaques par script intersites (XSS) ;
- Les ports ouverts et les services non sécurisés.

Quelques mesures de sécurité à mettre en place :

- La validation des entrées utilisateur ;
- La gestion des identités et des accès ;
- La sécurité du code ;
- La protection contre les attaques par injection de code ;
- La mise à jour régulière des applications.

3. La sécurité des bases de données :

Les mécanismes de sécurité pour les bases de données :

- La mise en place de systèmes d'authentification et d'autorisation pour l'accès aux données ;

- La mise en place de contrôles d'accès pour restreindre l'accès aux données sensibles ;
- La mise en place de mécanismes de chiffrement pour protéger les données stockées ;
- La mise en place de sauvegardes régulières pour garantir la récupération des données en cas de sinistre.

Comment les pirates les exploitent ?

Les attaques par injection SQL consistent à insérer des commandes SQL malveillantes dans les formulaires web.

Les pirates peuvent également utiliser des techniques d'ingénierie sociale pour obtenir des informations d'identification d'accès à la base de données.

Chapitre 5 : Sécurité des données

1. La classification et l'étiquetage des données :

Les différents types de données :

Type de données	Exemple	Niveau de classification	Étiquetage
Données publiques	Informations accessibles au public	Aucun	Aucun
Données internes	Documents internes à l'entreprise	Restreint	Interne
Données confidentielles	Informations sensibles de l'entreprise	Élevé	Confidentiel
Données personnelles	Informations personnelles des employés ou des clients	Élevé	Personnel

Les normes de sécurité :

Les normes de sécurité les plus courantes comprennent la norme ISO/CEI 27001 et le Règlement général sur la protection des données (RGPD) de l'Union européenne.

2. Le chiffrement des données :

Les différents types de chiffrement :

Type de chiffrement	Description
Chiffrement symétrique	Le chiffrement symétrique utilise la même clé pour chiffrer et déchiffrer les données
Chiffrement asymétrique	Le chiffrement asymétrique utilise une paire de clés (clé publique et clé privée) pour chiffrer et déchiffrer les données
Hachage	Le hachage est une méthode de chiffrement qui transforme les données en une empreinte numérique unique

Signature numérique	La signature numérique utilise une clé privée pour créer une signature unique qui peut être utilisée pour vérifier l'authenticité et l'intégrité des données
---------------------	--

Les normes et les réglementations :

- **La norme AES (Advanced Encryption Standard)** : Elle est considérée comme la norme de chiffrement la plus sûre,
- **La norme RSA** : Elle est souvent utilisée pour la création de clés de chiffrement,
- **La norme PCI-DSS (Payment Card Industry Data Security Standard)** : Elle s'applique aux entreprises qui stockent, traitent ou transmettent des données de cartes de crédit.

Les avantages et les limites des chiffrements :

Permet de protéger les informations sensibles, de garantir la confidentialité des données, de prévenir la fraude et de se conformer aux normes de conformité en matière de protection des données.

Cependant, il peut ralentir les performances du système, rendre l'accès aux données plus compliqué pour les utilisateurs autorisés, et ne pas être totalement invulnérable aux attaques des pirates informatiques.